

JANS AI Zentrum: Briefing und Offertanfrage für die IT-Architektur

Raphael Jans Architekten ETH/SIA · Grubenstrasse 37 · 8045 Zürich · Stand 19.09.2026 · Vertraulich

00 Big Points

00.1 Worum es geht. Das Büro betreibt seit März 2026 eine selbst gebaute KI-Betriebsumgebung, den JANS AI Hub. Er trägt heute Studien, Bauleitung, Korrespondenz, Buchhaltung und den Aufbau von Fachwissen. Gebaut hat ihn der Inhaber zusammen mit der KI (Claude Code), ohne IT-Fachperson.

00.2 Was gesucht ist. Ein AI- und IT-Ingenieur, der die IT-Architektur darunter fachgerecht neu baut und danach betreut: das JANS AI Zentrum, eine Plattform mit mehreren Fach-Hubs. Die KI baut weiterhin die Fachinhalte. Die Architektur, auf der sie läuft, kommt künftig vom Spezialisten.

00.3 Was bleibt und was ersetzt wird. Die Fachsubstanz bleibt: 51 Skills, 43 Agenten, 19 Wissensbasen, das Stilmodell des Büros, die Prozessketten. Ersetzt wird der Betriebs-Klebstoff: Netzlaufwerk als Rückgrat, Eigenbau-Sync, sieben parallele Scheduler, 22 Wächter-Scripts, Schutz per Prompt-Regel.

00.4 Der Befund in Zahlen. Die Ist-Analyse vom 19.09.2026 belegt 120 Schwachstellen, davon 25 kritisch. 43 % der unbeaufsichtigten Läufe schlagen fehl. Es gibt keine Tests, keine CI und keine belegte Wiederherstellungsprobe. Die Fachleistung des Systems ist hoch, das Fundament ist es nicht.

00.5 Ein kleiner Kern zuerst. Stufe 1 beseitigt nur die kritischen Befunde, auf möglichst wenig neuer Infrastruktur. Jede Ausbaustufe danach braucht einen geschäftlichen Auslöser und eine eigene Freigabe. Gesucht ist kein Grossprojekt, sondern ein tragfähiger Kern, der wachsen kann.

00.6 Was zu offerieren ist. Elf Pakete für Stufe 1 (AP0 bis AP10) und vier Ausbaupakete (AP11 bis AP14). AP0, Audit und Zielarchitektur mit Sofortmassnahmen, ist eigenständig beauftragbar. Offeriert wird je Paket, nicht je Hub. Offertfrist: _____.

01 Ausgangslage

01.1 Das Büro. Architekturbüro in Zürich, inhabergeführt, mit Ausbauabsicht auf einige Mitarbeitende. Eine Aktiengesellschaft ist in Gründung, es entstehen zwei Rechtsträger. Die Kundschaft liegt unter anderem im Spitalumfeld, entsprechend hoch sind die Ansprüche an Vertraulichkeit.

01.2 Der Hub in Zahlen. Stand 19.09.2026, gemessen am Repository und an den Betriebsjournalen.

Grösse	Wert
Skills, Agenten, Commands	51, 43, 13
Verhaltensregeln (Rules)	29, davon 24 in jeder Session geladen
Wissensbasen	19 mit 1'656 belegten Artikeln
Eigenbau-Connectoren	19 (Microsoft 365, bexio, Geodaten, Behördenportale u.a.)

Geplante Routinen	46 Task-Definitionen, dazu rund 30 launchd-Jobs
Shell-Scripts	84 mit 12'420 Zeilen
Repository	11'865 Commits seit 23.03.2026, 5'605 Dateien
Unbeaufsichtigte Läufe	2'543 in 7.5 Wochen, davon 43 % fehlgeschlagen
Hardware	3 Macs, 1 Synology NAS (6 TB, 93 % belegt), OPNsense, Tailscale
Umsysteme	Microsoft 365 (SharePoint 79 % belegt), bexio, Claude im Abo

01.3 Das Geschäftsmodell. Sechs produktisierte Dienstleistungen stehen im Service-Katalog: Machbarkeits-Studio, Immobilienbewertung, Ankaufsprüfung, Bauleitungs-Backend, Wettbewerbs-Fabrik, Energie-Vorabklärung. Ziel sind Fixpreisprodukte, ein Backend für Partnerbüros und interaktive, gehostete Studien für Bauherrschaften. Dafür braucht es später Mehrbenutzerbetrieb, Mandantentrennung und ein Kundenportal. Nichts davon ist heute vorhanden.

01.4 Sie beginnen nicht bei null. Der Hub hat sich selbst gründlich untersucht: Hub-Audit vom 12.08.2026, Spec zur Laufzeitschicht vom 30.08.2026, Systemanalyse vom 11.09.2026 mit Zielbild und Migrationsplan, dazu eine Betriebs-Chronik mit 95 dokumentierten Vorfällen. Diese Unterlagen und der Befundkatalog vom 19.09.2026 stehen nach Unterzeichnung einer Geheimhaltungsvereinbarung zur Verfügung.

02 Was erhalten bleibt, was ersetzt wird

02.1 Erhalten: die Fachsubstanz. Die Fach-Skills mit ihren Prozessketten (von der Unternehmerfindung bis zur Kostenkontrolle, von den Geodaten bis zum interaktiven Studio). Die Wissensbasen mit Quellenpflicht und Statusmodell. Das Stilmodell des Büros mit täglicher Prüfung gegen echte Vorlagen. Die Kontierungsregeln und die Geodaten-Kette. Alles liegt als Markdown und Code vor und ist plattformneutral.

02.2 Erhalten: die Betriebskultur. Jeder Vorfall ist mit Messwert, Ursache und Lehre dokumentiert. Eingriffe sind umkehrbar, Zahlungen ausgeschlossen, heikle Aufgaben laufen nur nach Freigabe. Diese Regeln sind die Anforderungen an die neue Plattform, künftig technisch durchgesetzt statt als Text.

02.3 Ersetzt: der Betriebs-Klebstoff. Das Netzlaufwerk als Rückgrat der Automatik. Der Eigenbau-Committer auf dem NAS. Sieben Scheduler und fünf Datei-Queues. 22 Wächter- und Heil-Scripts. Die Desktop-App als Scheduler der operativen Aufsicht. Alarmierung über den Mail-Client. Berechtigungen, die nur als Textregel bestehen.

03 Befund: zehn Querschnittsthemen

03.1 Ein Netzlaufwerk als Rückgrat. Skills, Regeln, Wissen, Logbuch und Queues liegen auf einer SMB-Freigabe. Reisst der Mount ab, ist die Station für den ganzen Hub blind. Belegt sind sieben Ausfalltage in sechs Wochen und bis 346 Abrisse an einem Tag. 730 Zeilen verdrahten den Pfad fest.

03.2 Kein Job-System. Sieben Feuermechanismen und fünf dateibasierte Queues laufen nebeneinander, ohne gemeinsamen Zustand, ohne Retry-Grenze, ohne Idempotenz. Folge: 43 % Fehlläufe, 699 ertraglose Läufe in einer Nacht, vier Tage ohne Tagesbriefing, 66 Stunden Ausfall der Aufsicht, weil der Scheduler eine Desktop-App mit persönlichem Login ist.

03.3 Identität und Berechtigung ohne Least Privilege. Die Automatik arbeitet mit sehr weiten Rechten auf Umsysteme und Stationen, Schlüssel werden von Hand zwischen den Geräten kopiert, Secrets liegen an fünf Orten. Eine Geräteverwaltung fehlt. Die Details stehen im Befundkatalog.

03.4 Agentische Risiken sind nicht adressiert. Die KI liest täglich Mails und Anhänge und darf handeln (versenden, buchen). Eine Trennung zwischen lesendem und handelndem Agenten gibt es nicht, Prompt-Injection kommt im ganzen System nicht vor. Die Grenze schreibender Aktionen hängt an Textregeln und an einem nicht steuerbaren Klassifikator des Herstellers.

03.5 Datenschutz ohne Rahmen. Personendaten Dritter (Mailkorpora, Kontaktregister, Kundenwissen, Fristenregister) liegen versioniert im Repository und werden automatisch ausser Haus gesichert. Datenklassen, Bearbeitungsverzeichnis, Auftragsbearbeitungsverträge und Löschkonzept fehlen. Ausschlusslisten für heikle Ordner bestehen nur als Text.

03.6 Backup und Notfall nicht belegt. Für 6 TB Bürodats ist keine getestete 3-2-1-Sicherung dokumentiert, für Microsoft 365 und beXio gar keine. Wiederherstellungsziele und ein Notfallplan fehlen. Die Always-On-Station übersteht keinen unbeaufsichtigten Neustart, eine USV ist nicht dokumentiert.

03.7 Die Überwachung hängt am Überwachten. Wächter schreiben ihren Zustand auf das NAS, das sie überwachen. Einziger Alarmkanal ist der Mail-Client, der mehrfach still ausfiel. Ein Fernzugangs-Ausfall von vier Tagen wurde viermal korrekt gemessen und nie gemeldet. Ein Buchhaltungszugang war 36 Tage tot.

03.8 Kein Engineering-Fundament. Keine Tests, keine CI, kein Lockfile, kein Staging. Skills und Regeln werden direkt in Produktion editiert und wirken sofort auf allen Stationen und in allen Nachtläufen. Der Grundkontext jeder Session ist trotz zweier Diäten auf 151 kB gewachsen.

03.9 Auf eine Person verdrahtet. Ein Benutzer, eine Identität, ein Absender, ein Logbuch. Für Mitarbeitende gilt heute voller Zugriff ohne Rollenmodell. Kundenstudios liegen ohne Anmeldung hinter einem Zufallslink. Zwei Rechtsträger und Partnerbüros lassen sich so nicht abbilden.

03.10 Worauf Sie bauen können. Netz ohne offene Ports, Fernzugang nur über Tailscale. Secrets nie im Repository. Freigabe-Schwelle, Aktions-Whitelist und Widerrufsfenster als gelebte Praxis. Ein Lauf-Journal mit Kosten, Dauer und Ergebnis je Lauf. Ein fertiges Zielbild für den Umbau der Datenhaltung. Eine Messkultur, die jede Abnahme leicht macht.

04 Zielbild: eine Plattform, mehrere Hubs

04.1 Grundsatz. Das JANS AI Zentrum besteht aus einem Plattform-Hub, den der Ingenieur baut und verantwortet, und aus Fach-Hubs, die das Büro mit der KI auf dieser Plattform weiterbaut. Beilage 1 zeigt Ist und Soll auf einer Seite.

04.2 Hubs sind Grenzen, keine Systeme. Ein Hub ist ein Namensraum mit eigenem Berechtigungsprofil, eigener Dienstidentität und eigenem Datenraum. Technisch erzwungen werden wenige Vertrauenszonen: die Plattform, eine Inhaber-Zone für Finanzen, Stilkorpus und

Kontaktregister, die Projekt- und Kundendaten je Projekt und Rechtsträger, das mandantenneutrale Wissen mit einer Unterzone für lizenzgebundene Inhalte, und die Aussenzone Portal.

04.3 Die Hubs in drei Gruppen.

Gruppe	Hub	Zweck	Nutzer
Fundament	Plattform-Hub	Identität, Laufzeit, Daten, Integration, Sicherheit, Monitoring, Delivery	Ingenieur, Inhaber
Fundament	Aufsichts-Hub	Tagesbriefing, Fristen, Logbuch, Freigabe-Inbox, Cockpit	Inhaber
Facharbeit	Wissens-Hub	Normen, Baurecht, Kennwerte, Lern-Loops, Suche	alle intern, lesend
Facharbeit	Studien-Hub	Machbarkeit, Volumen, Bewertung, Ankauf, Energie	Inhaber, Mitarbeitende
Facharbeit	Projekt-Hub	Ausschreibung bis Kostenkontrolle, Protokolle, Pendenzen	Inhaber, Mitarbeitende je Projekt
Facharbeit	Wettbewerbs-Hub	Programm, Flächennachweis, Konformität, Bericht, Plakat	Inhaber, Mitarbeitende
Geschäft	Finanz-Hub	bexio, Mahnwesen, Zahlungsabgleich, zwei Rechtsträger	Inhaber, Treuhand lesend
Geschäft	Akquise- und Stimm-Hub	Stilmodell als Dienst, Website, LinkedIn, Leads	Inhaber, Mitarbeitende ohne Korpus
Geschäft	Kundenportal	Studios und Berichte mit Anmeldung, Ablauf, Protokoll	Bauherrschaften, Partner

04.4 Zwei Hubs mit Sonderstatus. Der Aufsichts-Hub liest täglich fremde Inhalte und handelt nach aussen. Er ist der risikoreichste Hub, wird zuerst migriert und erhält die Trennung von Leser und Handelndem zuerst. Der Projekt-Hub trägt die laufenden Bauprojekte mit Fristen. Er darf im Umbau nie stehen und wird zuletzt angefasst.

04.5 Datenklassen. K1 öffentlich, K2 intern, K3 vertraulich (Projekt, Kunde), K4 Personen- und Finanzdaten, dazu die Achse «lizenzgebunden» für Normen- und Buchdestillate, die nie extern gespiegelt werden. Je Klasse ist festzulegen, was in den KI-Kontext, in Git und in die Cloud darf. Die zwei Rechtsträger sind Mandanten im Projekt- und im Finanz-Hub, keine eigenen Hubs. Das Mandantenfeld gehört ab dem ersten Datenbankschema ins Datenmodell.

04.6 Die Schichten des Plattform-Hub.

Schicht	Anforderung	Ersetzt heute
Identität und Geräte	ein Konto je Person, MFA, schlanke Geräteverwaltung, Rollen	geteilte Schlüssel, voller Zugriff für alle
Laufzeit und Job-System	ein Scheduler mit Zustand, Retry, Timeout, Budget, Nachholen	7 Scheduler, 5 Datei-Queues, Desktop-App
Agenten-Laufzeit	definierte Umgebung, Profil je Jobklasse, Sandbox	pauschales Shell-Recht, Schutz per Prompt
Daten	Git für Code und Wissen, Datenbank für Zustand und Register, Objektspeicher für Artefakte	alles in einem Repository auf SMB

Integration	Secrets-Speicher, geprüfte Connectoren, später typisierte MCP-Server	19 Einzel-CLIs, Secrets an fünf Orten
Sicherheit und DSGVO	Freigabeschicht ausserhalb der KI, Audit-Log, Datenklassen	Textregeln und Hersteller-Klassifikator
Backup und Notfall	3-2-1, Restore-Probe, RPO und RTO, Sicherung M365 und bexio	unbelegte Einzelaussage
Monitoring und Alarm	unabhängig vom Überwachten, Push-Alarm, Kosten je Lauf	Wächter-Scripts, Alarm per Mail-Client
Delivery	Review, CI, Evals, Staging, Releases	Edit direkt in Produktion
Wissensdienst (Ausbau)	Volltext- und Vektorsuche über alle Wissensbasen	grep über Dateien, Register bis 1 MB

04.7 Das Zielbild ist ein Vorschlag. Hub-Schnitt, Zonen und Schichten sind die Sicht des Auftraggebers. APO bestätigt oder korrigiert sie.

05 Leitplanken

05.1 Substanz vor Plattform. Fach-Skills, Wissensbasen und Stilmodell werden nicht neu geschrieben. Markdown bleibt das Autorenformat.

05.2 Kleiner Kern. Ein Host, eine Datenbank, wenige gemanagte Dienste. Die Zahl der selbst betriebenen Dienste ist ein Abnahmekriterium. Je Schicht ein Architekturentscheid mit Alternative und Ausstiegsweg.

05.3 Standard vor Eigenbau, gemanagt vor selbst betrieben, wo ein Dienst mit Standort Schweiz oder EU genügt.

05.4 Risiko zuerst. Backup, Alarm, Schlüssel und Geräte kommen vor dem Umbau von Daten und Laufzeit. Sofortmassnahmen sind additiv und einzeln abschaltbar.

05.5 KI-bediener, aber geführt. Alles ist per CLI, API oder Infrastructure as Code bedienbar, damit die KI weiterarbeiten kann. Änderungen an Plattform, Policy und Profilen laufen über Review und CI, auch für Bots.

05.6 Minimaler Eigenbetrieb. Der Inhaber ist Architekt, nicht Administrator. Gesucht ist eine Lösung mit Wartungsvertrag, nicht ein zweiter Beruf. Sein Zeitbudget je Woche ist Teil der Planung.

05.7 Datenhoheit. Schweizer DSGVO, Datenstandort Schweiz oder EU bevorzugt. Die Geheimhaltungsklauseln der Bauherrschaften werden vor jedem Standortentscheid geprüft.

05.8 macOS bleibt. Mail-Versand, ArchiCAD, Cinema 4D, InDesign und Rhino sind an Macs gebunden. Die Macs bleiben Arbeitsplätze, einer dient als Mac-Worker der Plattform. Die Festplattenverschlüsselung wird nirgends abgebaut.

05.9 Microsoft 365 und bexio bleiben. SharePoint ist die Projektablage, bexio die Buchhaltung.

05.10 Etappen mit Rückfallweg und Haltepunkten. Kein Big Bang. Parallelbetrieb, bis die Abnahme je Etappe gemessen ist. Nach jeder Etappe kann der Auftraggeber anhalten.

05.11 Baustopp für Klebstoff. Ab Auftrag AP0 entstehen im Hub keine neuen Wächter, Scheduler und Queues mehr. Das Ziel soll sich während des Umbaus nicht täglich bewegen.

05.12 Übergabefähig. Code, Konfiguration und Dokumentation liegen im Repository des Auftraggebers. Kein proprietärer Lock-in, dokumentierter Ausstieg, Nachbau durch eine zweite Fachperson möglich.

06 Leistungspakete

06.0 Übersicht. Stufe 1 ist der kleine Kern und beseitigt die kritischen Befunde. Die Ausbaupakete werden einzeln und nur bei ihrem Auslöser bestellt.

Nr.	Paket	Stufe	Wer baut
AP0	Audit, Zielarchitektur, Sofortmassnahmen	1	Ingenieur
AP1	Host, Netz, Geräte	1	Ingenieur
AP2	Backup, Restore, Notfallhandbuch	1	Ingenieur
AP3	Monitoring und Alarm	1	Ingenieur
AP4	Secrets und Least Privilege	1	Ingenieur
AP5	Daten und Sync	1	gemeinsam
AP6	Job-System und Agenten-Laufzeit	1	gemeinsam
AP7	Agentische Sicherheit und Freigabeschicht	1	Ingenieur
AP8	Datenschutz nach DSGVO	1	gemeinsam
AP9	Delivery: Review, CI, Evals	1	gemeinsam
AP10	Rückbau, Übergabe, Wartung	1	Ingenieur
AP11	Studio-Hosting mit Anmeldung	Ausbau	Ingenieur
AP12	Wissensplattform mit Hybrid-Suche	Ausbau	gemeinsam
AP13	Integrations-Hub (MCP)	Ausbau	gemeinsam
AP14	Mitarbeitende, Mandanten, Portal	Ausbau	Ingenieur

06.1 AP0 Audit, Zielarchitektur, Sofortmassnahmen. Verifikation des Befundkatalogs am lebenden System, auch der Punkte, die aus dem Repository nicht prüfbar sind (NAS, Firewall, Tailnet, Entra, GitHub). Bedrohungsmodell für ein agentisches System. Abhängigkeitskarte aller Routinen und der Entscheid, welche gar nicht migriert werden. Kostenmodell der KI-Nutzung in drei Szenarien aus den Journaldaten. Zielarchitektur mit mindestens zwei Varianten und den Kosten über drei Jahre. Ein moderierter Entscheid-Workshop mit Vorschlagswerten für den Inhaber. Sofortmassnahmen in der ersten Woche: Backup nachweisen und eine Datei wirklich zurückholen, zweiter Alarmkanal, Dead-Man-Switch für Tagesbriefing und Fristen-Radar, Zwischenschutz für schreibende Aktionen. Abnahme: jeder kritische Befund ist einem Paket zugeordnet, je Schicht liegt ein Architekturentscheid vor, die Preise für AP1 bis AP10 sind verbindlich.

06.2 AP1 Host, Netz, Geräte. Ein kleiner, headless betriebener Linux-Host oder eine gleichwertige VM bei einem Schweizer Hoster, verschlüsselt mit unbeaufsichtigtem Wiederanlauf, USV, Konfiguration als Code. Netz in Zonen, Fernzugang als Systemdienst mit ACL und Schlüsselablauf. Schlanke Geräteverwaltung für die drei Macs mit Schlüssel-Hinterlegung und Fernlöschung, saubere Neuinstallation der dritten Station. Abnahme: Stecker-Probe bestanden (alle Dienste ohne Person

innert 10 Minuten zurück, Datenträger bleiben verschlüsselt), Host in zwei Stunden aus dem Repository neu aufgesetzt, ein verlorenes Notebook innert einer Stunde gesperrt und seine Schlüssel widerrufen.

06.3 AP2 Backup, Restore, Notfallhandbuch. Dateninventar mit RPO und RTO je Klasse. Sicherung nach 3-2-1 für Bürodaten, Host, Microsoft 365 und beXio, mit verschlüsseltem Ziel ausser Haus. Kapazitäts- und Nachfolgeentscheid für das NAS, Speicherstrategie für den SharePoint-Pool. Berechtigungsmodell des Dateiservers je Person, Dienst und Datenklasse. Löschkonzept, das mit unveränderbaren Sicherungen vereinbar ist. Notfallhandbuch je Szenario samt Stellvertretung. Abnahme: protokollierte Wiederherstellung je Datenklasse, RPO und RTO vom Inhaber unterschrieben und in der Probe eingehalten, eine Notfallübung durchgeführt.

06.4 AP3 Monitoring und Alarm. Überwachung ausserhalb der überwachten Systeme: Erfolgs-Heartbeat je Job, Erreichbarkeit von aussen, echter Lese-Check je Connector, Ablauf aller Tokens und Zertifikate, Zustand und Füllstand von NAS und SharePoint, Uhrendrift der Stationen. Alarm über einen unabhängigen Kanal mit Zustellnachweis und Eskalation. Abnahme: simulierter Ausfall von Host, NAS, Tunnel und einem Aufsichtsjob ist je innert 15 Minuten auf dem Telefon des Inhabers, auch bei geschlossenem Mail-Client und leerem KI-Kontingent.

06.5 AP4 Secrets and Least Privilege. Ein Secrets-Speicher als einzige Quelle mit Inventar, Rotation und Ablaufüberwachung. Rechte der Microsoft-365-Anbindung auf das Nötige zugeschnitten und getrennt nach Lesen, Schreiben, Senden, Schlüssel je Gerät und nicht exportierbar. Härtung des Git-Kontos. Abnahme: kein Klartext-Secret auf einer Station oder dem NAS, keine Anbindung mit tenantweiten Vollrechten mehr aktiv, alte Zugänge erst deaktiviert und nach 30 Tagen gelöscht.

06.6 AP5 Daten und Sync. SMB aus dem kritischen Pfad, aufbauend auf der vorhandenen Systemanalyse: Git als einzige Quelle, lokale Klone, Pfadauflösung per Konfiguration. Schnitt des Repository in Plattform, Harness, Wissen und Privates. Register, Journale und Telemetrie in die Datenbank, mit Kommandozeile für die Agenten und lesbarem Export. Binärdaten in den Objektspeicher. Hub-Ausgaben serverseitig in SharePoint statt über lokale Sync-Ordner. Abnahme: alle Stationen arbeiten bei ausgehängtem NAS, kein Status-Commit mehr, 14 Tage ohne Divergenz.

06.7 AP6 Job-System und Agenten-Laufzeit. Ein Scheduler mit persistentem Zustand, Retry mit Obergrenze, Timeout, Idempotenz, Budget je Lauf, Nachholen und Abbruch bei fehlendem Ertrag. Eine Agenten-Laufzeit mit gepinnter Version und genau einer Anmeldungsquelle, je Jobklasse umstellbar zwischen Abo und API. Mac-Worker unter eigenem macOS-Benutzer nur mit dem Geschäftskonto, der Aufträge abholt statt von aussen angesprochen zu werden. Migration in Wellen: Aufsicht zuerst im Schattenbetrieb (beide erzeugen, nur das alte System sendet), operative Jobs danach, Lern-Loops zuletzt. Getrennte Kontingente für operative und lernende Läufe. Authentisierter Weg, unterwegs Aufträge einzureichen. Abnahme: technische Fehlläufe unter 5 % über 14 Tage (Kontingent-Aufschübe zählen als aufgeschoben), kein Doppellauf, Tagesbriefing und Fristen-Radar 14 Tage in Folge geliefert, jede Routine mit Takt, letztem Ergebnis und nächstem Lauf an einem Ort sichtbar.

06.8 AP7 Agentische Sicherheit und Freigabeschicht. Berechtigungsprofile je Jobklasse, vom werkzeuglosen Leser für Mail, Web und PDF bis zum aussenwirksamen Profil, auch für interaktive Sitzungen und Cloud-Connectoren. Freigabeschicht ausserhalb der KI für senden, buchen, mahnen und Berechtigungen ändern: Regeln als Code, Betrags- und Mengengrenzen, authentifizierte Freigabe per Push, zuerst beobachtend, dann erzwingend. Die KI hält die Schreibzugänge zu Mailversand und Buchhaltung nie selbst. Signierte Aufträge statt Ausführung aus Dateien. Audit-Log ausserhalb der Schreibreichweite der Agenten. Testkonten für Buchhaltung, Postfach und SharePoint. Abnahme: wiederkehrende Red-Team-Suite in der CI mit null Aussenwirkungen und null Datenabflüssen, die Freigabeschicht verweigert bei eigenem Ausfall, Änderungen an Policy und Profilen nur durch benannte Personen.

06.9 AP8 Datenschutz nach DSG. Datenklassen, Bearbeitungsverzeichnis, Übersicht der Auftragsbearbeiter mit Datenstandort, Lösch- und Aufbewahrungskonzept, Folgenabschätzung für das agentische System, Ablauf bei einer Verletzung der Datensicherheit. Klärung der Vertragsgrundlage der KI-Nutzung, auch der interaktiven. Personendaten aus Grundkontext und Repository in einen zugriffsgesteuerten, löschfähigen Speicher. Repositories mit bereinigtem Stand neu aufsetzen, das alte einfrieren. Technisch erzwungene Ausschlusslisten. Juristische Fragen benennen Sie, beantworten muss sie eine Rechtsfachperson, die der Auftraggeber früh beizieht. Abnahme: ein gesperrter Ordner ist für Inventar- und Lernläufe technisch nicht lesbar, ein Commit mit Personendaten oder Secret wird abgewiesen, Verzeichnis und Verträge liegen vor.

06.10 AP9 Delivery. Branch, Review, CI, Tag und Rollback für Plattform und Harness. Produktion zieht nur freigegebene Stände. Lern-Loops schreiben in einen Staging-Zweig mit Diff-Gate, die Selbstverbesserung erzeugt Vorschläge statt Direktedits. Festgelegt ist, welche Änderungsklassen nach grüner Prüfung automatisch übernommen werden und welche der Inhaber freigibt, auf dem Telefon, mit einem Klick und Frist. Evaluations-Suite aus den vorhandenen Goldstandards, Tests der fachlichen Rechenkerne, gepinnte Werkzeuge. Abnahme: direkter Push in die Produktion ist auch für Bots gesperrt, Grundkontext dauerhaft unter 100 kB, Rollback in 10 Minuten vorgeführt.

06.11 AP10 Rückbau, Übergabe, Wartung. Stilllegen des Klebstoffs mit 60 Tagen Vorhaltung. Runbooks aus der Betriebs-Chronik, auch für Sicherheitsvorfälle. Schulung des Inhabers. Wartungsvertrag mit Reaktionszeiten, Patch-Fenstern, Stellvertretung, halbjährlichem Review und Kostenübersicht. Abnahme: eine zweite Fachperson baut einen Dienst aus dem Repository nach, der gesunkene Betriebsaufwand des Inhabers ist nach drei Monaten gemessen.

06.12 AP11 Studio-Hosting mit Anmeldung. Auslöser: der nächste zahlende Studio-Kunde. Statisches Hosting in der Schweiz oder EU hinter Anmeldung, mit Ablaufdatum, Widerruf, Zugriffsprotokoll und Deployment aus versionierter Quelle. Rechenkern aus einer Quelle mit Paritätstests. Dieses Paket ist klein und darf früh kommen, weil es das nächste verkaufbare Produkt trägt.

06.13 AP12 Wissensplattform. Auslöser: messbar bremsendes Retrieval. Volltext- und Vektorsuche über alle Wissensbasen, Provenienz mit Dokument-ID und Quellversion, Evaluations-Sets je

Wissensbasis, Auslieferung als ein Werkzeug für die Agenten. Die Erschliessung des Archivs mit 1.9 TB ist ein eigenes Vorhaben und nicht Teil dieses Pakets.

06.14 AP13 Integrations-Hub. Auslöser: neue Integrationen oder Mitarbeitende, die dieselben Werkzeuge brauchen. Typisierte MCP-Server je Domäne, gemeinsames Connector-SDK, Katalog als Daten, Sanierung der fragilen Portal-Logins.

06.15 AP14 Mitarbeitende, Mandanten, Portal. Auslöser: erste Anstellung, Start der AG, erster Partnervertrag. Rollen, Zugriff im Namen der anfragenden Person, Mandantenräume, Portal für Partner und Bauherrschaften.

07 Rollenteilung

07.1 Der Ingenieur baut und verantwortet den Plattform-Hub, setzt die Leitplanken für die KI und nimmt Änderungen an Plattform, Policy und Profilen ab. Er ist selbst Auftragsbearbeiter mit hohen Rechten: benanntes Admin-Konto mit MFA, zeitlich begrenzte Rechte, protokollierte Eingriffe, geregelter Austritt.

07.2 Das Büro mit der KI baut die Fach-Hubs weiter, stellt Pfade und Routinen auf die neue Plattform um und liefert Messwerte und Dokumentation zu. Diese Eigenleistung weisen Sie in der Offerte je Paket aus.

07.3 Der Inhaber entscheidet Varianten, Budget, Datenstandort und Freigaben und nimmt jede Etappe ab. Sein Zeitbedarf je Woche steht in der Offerte.

07.4 Die KI als Werkzeug des Ingenieurs. Das System ist vollständig dokumentiert und per KI bearbeitbar. Wo Sie dadurch Aufwand sparen, weisen Sie das im Preis aus.

08 Etappen

Etappe	Inhalt	Ergebnis
E0	Geheimhaltung, Einsicht, Begehung, Offerte	Auftrag APO
E1	AP0 mit Sofortmassnahmen	Architekturentscheid, Festpreise
E2	Risiko zuerst: AP1 bis AP4	gesicherte Daten, Alarm, enge Rechte. Haltepunkt
E3	Daten und Laufzeit: AP5, AP6, danach vier Wochen Messung	ein Job-System ohne SMB. Haltepunkt
E4	Härtung: AP7, AP8, AP9	Freigabeschicht, DSGVO-Rahmen, geprüfte Releases
E5	AP10	Klebstoff stillgelegt, betreuter Betrieb
Ausbau	AP11 bis AP14 je bei Auslöser	verkaufbare Produkte, Team, Mandanten

08.1 Termine. Gewünschter Beginn APO: _____. Gewünschter Abschluss Stufe 1: _____.

09 Anforderungen an die Offerte

09.1 Form. PDF, höchstens 15 Seiten, dazu das Preisblatt je Paket.

09.2 Preise. AP0 als Festpreis. AP1 bis AP10 je als Festpreis oder Kostendach in Ingenieurtagen, verbindlich nach AP0. AP11 bis AP14 als Richtpreis mit Annahmen. Wartung als Monatspauschale mit Leistungsumfang, dazu Stundenansätze nach Funktion. Alle Preise in CHF, exklusive MWST, MWST ausgewiesen.

09.3 Eigenleistung und Zeitbedarf. Je Paket die vorausgesetzte Eigenleistung des Büros mit der KI in Tagen und der Zeitbedarf des Inhabers je Woche, samt Wartungsfenstern.

09.4 Varianten. Mindestens zwei Architekturvarianten mit den Gesamtkosten über drei Jahre: Hardware, Lizenzen, Hosting, KI-Nutzung, Wartung. Dazu die kleinste sinnvolle Erstbestellung.

09.5 Dienste. Welche Dienste Sie selbst betreiben, welche Sie gemanagt beziehen, mit Datenstandort und Auftragsbearbeitungsvertrag. Die Gesamtzahl.

09.6 Team. Wer arbeitet, mit welcher Erfahrung in agentischen Systemen, macOS-Flotten als Worker, Microsoft Entra und Graph unter Least Privilege und im KMU-Betrieb. Referenzen, Verfügbarkeit, Stellvertretung.

09.7 Eigentum. Sämtliche Arbeitsergebnisse gehören dem Auftraggeber und liegen in seinem Repository.

09.8 Vertraulichkeit und Datenschutz. Geheimhaltungsvereinbarung vor Einsicht in den Befundkatalog. Vereinbarung zur Auftragsbearbeitung. Zugriff nur mit persönlichen, protokollierten Konten.

09.9 Haftung. Nachweis der Berufshaftpflicht, Aussage zur Haftung für Datenverlust während der Migration.

09.10 Bindefrist. Drei Monate ab Offertdatum.

10 Fragen, die die Offerte beantwortet

10.1 Standort der Plattform. Eigener Host im Büro, VM in der Schweiz oder EU, oder Mischform? Ab welcher Grösse oder welchem Risiko raten Sie zum einen oder anderen? Wie erreichen Sie den unbeaufsichtigten Wiederanlauf, ohne die Verschlüsselung abzubauen?

10.2 Job-System. Welches Werkzeug für ein Ein-Personen-Büro, mit welchem Ausstiegsweg? Wie migrieren Sie 46 Routinen ohne Unterbruch der Aufsicht?

10.3 Agenten-Laufzeit. Abo oder API für unbeaufsichtigte Läufe: was lassen die aktuellen Bedingungen des Anbieters zu, was kostet es? Das Journal weist rund USD 2'400 API-Äquivalent in 7.5 Wochen aus, vor Bereinigung der Fehlläufe und ohne die App-Routinen. Wie sieht das System aus, wenn nur fünf bis zehn operative Jobs unbeaufsichtigt laufen dürfen?

10.4 Agentische Sicherheit. Wie trennen Sie lesende von handelnden Agenten, wie isolieren Sie die Schreibzugänge, wie weisen Sie die Wirkung wiederkehrend nach?

10.5 Mac-Worker. Wie betreiben Sie Mail-Versand, CAD und Render als Dienst neben interaktiver Arbeit, nach einem Neustart und ohne ruhende Secrets? Lässt sich der Mailweg über Entwürfe im Postfach vereinfachen?

10.6 Microsoft 365 und Secrets. Wie schneiden Sie die Rechte zu, welches Produkt für Secrets, welche Rotation?

10.7 Datenschnitt. Was bleibt in Git, was geht in Datenbank und Objektspeicher? Was muss für die spätere Mandantentrennung jetzt schon im Datenmodell stehen?

10.8 Backup. Ihr Vorschlag für 6 TB Bürodaten, Microsoft 365, bexio und den Host, mit Standorten, Monatskosten und Probeplan.

10.9 Monitoring. Welcher Stack ohne Dashboard-Ballast, welcher Alarmkanal, was kostet er im Monat?

10.10 Datenschutz. Was decken Sie ab, wofür braucht es eine Rechtsfachperson, und in welcher Reihenfolge?

10.11 KI-Bedienbarkeit. Was darf die KI über Vorschläge ändern, welche Prüfungen blockieren, wie bleibt der Inhaber dabei nicht der Engpass?

10.12 Betrieb. Reaktionszeiten, Patch-Rhythmus, Stellvertretung, Fernzugriff, Ausstieg.

10.13 Streichen. Welche der 84 Scripts und 22 Wächter streichen Sie ersatzlos, welche übernehmen Sie als Anforderung? Was würden Sie für ein Büro mit ein bis sechs Personen ganz weglassen?

10.14 Widerspruch. Welche Risiken fehlen in den Befunden, und welche Annahmen dieser Anfrage halten Sie für falsch?

11 Bewertung der Offerten

Kriterium	Gewicht
Verständnis und Qualität der Lösung	30 %
Erfahrung und Referenzen	20 %
Preis und Kostentransparenz über drei Jahre	20 %
Betriebskonzept und Wartung	15 %
Vorgehen, Etappierung, Risiko	15 %

12 Ablauf

12.1 Geheimhaltung. Unterzeichnung der Vereinbarung, danach Zugang zu Befundkatalog, Hub-Audit und Systemanalyse.

12.2 Begehung. Termin im Büro mit Einsicht in das laufende System: _____.

12.3 Rückfragen. Schriftlich bis _____ an rj@raphaeljans.ch.

12.4 Offerte. Eingang bis _____.

12.5 Vergabe. Entscheid bis _____, zuerst APO.

13 Beilagen

13.1 Beilage 1. Architektur Ist und Soll auf einer Seite.

13.2 Nach Geheimhaltungsvereinbarung. Befundkatalog vom 19.09.2026 (120 Befunde mit Beleg), Hub-Audit vom 12.08.2026, Spec Laufzeitschicht vom 30.08.2026, Systemanalyse und Vertiefung vom 11.09.2026, Service-Katalog, Geschäftsmodell.

Raphael Jans, Founder I MD

MSc ETH I SIA

rj@raphaeljans.ch

+41 79 846 11 65

www.raphaeljans.ch